

Use this checklist to verify your medical device penetration testing program satisfies **FDA premarket cybersecurity guidance (2023)** for 510(k), PMA, and De Novo submissions. Testing must cover the full device ecosystem: firmware, companion apps, APIs, cloud backends, and integrations. **Reports must be repeatable, evidence-driven, and formatted for FDA reviewer credibility.**

FW – FIRMWARE & HARDWARE

APP – COMPANION APPS

API – BACKEND & CLOUD

RPT – REPORTING & EVIDENCE

PM – POST-MARKET

01 PLANNING & AUTHORIZATION

FDA 2023 / AAMI TIR57

- ☐ Define **system boundaries** covering the full device ecosystem: device hardware, companion apps, APIs, cloud backend, and third-party integrations **CRITICAL**
- ☐ Confirm a **release-representative build** is available for testing; results from a non-final build may lack credibility for submission **CRITICAL**
- ☐ Obtain **written Rules of Engagement** signed by the device manufacturer before testing begins **CRITICAL**
- ☐ Identify all **trust boundaries and data flows** between device, apps, and cloud services **HIGH**
- ☐ Document **testing access model**: blackbox, graybox, or whitebox; include rationale in the report **HIGH**
- ☐ Align test scope with the **software bill of materials (SBOM)** and cybersecurity bill of materials (CBOM) **HIGH**

02 DEVICE HARDWARE & FIRMWARE

FDA 2023 / IEC 62443

- ☐ Test **firmware update mechanisms**: validate code signing, integrity checks, and downgrade/rollback prevention **CRITICAL**
- ☐ Enumerate **exposed services and ports**; identify insecure defaults and unnecessary services **CRITICAL**
- ☐ Check for **hardcoded credentials**, secrets, or API keys embedded in firmware or device software **CRITICAL**
- ☐ Assess **debug interfaces** (JTAG, UART) for unauthorized physical access paths **HIGH**
- ☐ Test **wireless communication security**: BLE, Wi-Fi, cellular, and proprietary RF protocols where applicable **HIGH**
- ☐ Validate **secure boot enforcement** and physical tamper protections on in-scope devices **MEDIUM**

03 COMPANION APPS (MOBILE & DESKTOP)

FDA 2023 / OWASP MASVS

- ☐ Test for **insecure token and session storage**: identify credential leakage in local storage or shared preferences **CRITICAL**
- ☐ Assess **app-to-API trust assumptions**: attempt to bypass or downgrade authentication between app and backend **CRITICAL**
- ☐ Test for **missing certificate pinning**: attempt man-in-the-middle attacks on app-to-server communication **HIGH**
- ☐ Identify **insecure local storage** of patient data or device credentials on the mobile device **HIGH**
- ☐ Assess **input validation** and injection handling across all app data entry points **HIGH**
- ☐ Validate **app permissions**: confirm the app does not request excessive OS-level permissions **MEDIUM**

04 BACKEND APIS & CLOUD INFRASTRUCTURE

FDA 2023 / AAMI TIR57

- ☐ Test for **broken object-level authorization** (BOLA/IDOR): attempt to access another patient's or device's data **CRITICAL**
- ☐ Assess **multi-tenant isolation**: confirm one device or user cannot reach data belonging to another tenant **CRITICAL**
- ☐ Test for **excessive data exposure** via APIs: verify endpoints return only the minimum necessary fields **HIGH**
- ☐ Validate **rate limiting** and brute-force resistance on all authentication and sensitive endpoints **HIGH**
- ☐ Assess **cloud storage configurations**: identify publicly accessible buckets or misconfigured IAM policies **HIGH**
- ☐ Test **CORS configuration** and HTTP security headers across all web-facing endpoints **MEDIUM**

05 DATA INTEGRITY & PATIENT SAFETY

FDA 2023 / HIPAA

- ☐ Confirm **encryption at rest**: validate patient data and device telemetry are encrypted using current standards **CRITICAL**
- ☐ Validate **access control boundaries**: verify only authorized roles can issue device commands or modify settings **CRITICAL**
- ☐ Assess **audit logging**: confirm device and backend events are captured and tamper-resistant **HIGH**
- ☐ Test **encryption in transit**: confirm TLS 1.2 or higher on all data paths; flag any cleartext transmission **CRITICAL**
- ☐ Test **data integrity controls**: validate that device readings and patient records cannot be silently modified **HIGH**
- ☐ Identify **uncontrolled copies** of patient data in logs, debug outputs, or backup locations **MEDIUM**

06 REPORTING & SUBMISSION REQUIREMENTS

FDA 2023 / AAMI TIR57 / 21 CFR Part 820

// SCOPE_DOCS

- ☐ System boundary diagram
- ☐ CBOM and SBOM on file
- ☐ Signed Rules of Engagement
- ☐ Device build version documented
- ☐ Trust boundary map included

// FINDINGS_REPORT

- ☐ Executive summary for FDA reviewer
- ☐ Technical findings with CVSS scores
- ☐ Patient safety impact per finding
- ☐ FDA premarket guidance mapping
- ☐ Risk-ranked remediation list

// RETEST_EVIDENCE

- ☐ Verified fix documentation
- ☐ Updated results post-remediation
- ☐ Open findings w/ accepted risk rationale
- ☐ Remediation SLA: Critical 30 days

// POSTMARKET_PLAN

- ☐ Periodic retest cadence defined
- ☐ Vulnerability monitoring documented
- ☐ Architecture change re-test triggers
- ☐ Incident response plan reference